Данил Гранцев (Danil Grantsev)

Младший специалист по безопасности приложений (AppSec) / DevSecOps

Вьетнам (UTC+7) · Готов к удалённой работе · malooyy6@gmail.com · t.me/rezzodan · github.com/Rezzodan/Portfolio/tree/ru

О СЕБЕ

Full-Stack разработчик: **2,5 года разработки и эксплуатации финтех-платформы в продакшене** (ASP.NET Core, Python, React, Docker); перехожу в безопасность приложений. Я знаю, где ломаются реальные системы — аутентификация, интеграции, вебхуки, секреты, инфраструктура, — потому что сам их создавал и эксплуатировал. Отрабатываю атаку и защиту в домашней лаборатории: OWASP Top 10 на DVWA, Wazuh SIEM, Suricata IDS.

ОПЫТ РАБОТЫ

Full-Stack разработчик (платформа и инфраструктура) — ООО «100KVADRATOV» **Март 2024 — настоящее время**

Финтех / кредитный консалтинг · Уфа, Россия · удалённо

- Проектировал и поддерживал REST API (ASP.NET Core, FastAPI, Django REST Framework) с аутентификацией по JWT за обратным прокси Traefik с HTTPS; API обслуживали клиентское мини-приложение, админ-панель операторов, рабочее место юристов и партнёрский портал.
- Нашёл и исправил **дефект бизнес-логики** в вебхуках CRM, из-за которого по сделкам с рассрочкой повторно запускались выплаты партнёрам; заменил ошибочную логику явными правилами запрета повторного начисления для каждой воронки.
- Усилил защиту (hardening) робота автоматизации, управляемого вебхуками: проверки по списку разрешённых (allowlist) перед любым скачиванием файла или записью в CRM, callback-запросы с подписью HMAC, блокировки файлов на уровне каждой сделки и маскирование персональных данных (PII) в логах.
- Обрабатывал недоверенные документы — отчёты кредитных бюро (НБКИ, ОКБ), сканы паспортов и PDF — через конвейеры OCR и парсинга со строгой проверкой категорий до попадания данных в CRM.
- Обеспечивал работу **7 сервисов** в продакшене на собственном сервере (Docker Compose, Traefik TLS, PostgreSQL, собственный почтовый сервер): секреты только в конфигурации окружения, резервное копирование, восстановление после перезагрузки и регламенты реагирования на инциденты (runbooks); устранил 7+ инцидентов в продакшене.
- Выпустил одну кодовую базу на React/TypeScript одновременно как Mini App для Telegram и для MAX через слой-мост между платформами (platform bridge).

ПРОЕКТЫ ПО БЕЗОПАСНОСТИ

- **Лаборатория OWASP Top 10:** воспроизвёл SQL-инъекции (обход аутентификации, UNION) и отражённый XSS на DVWA и задокументировал способы исправления — параметризованные запросы, кодирование выходных данных, CSP, cookie с флагами HttpOnly и SameSite.
- **Обнаружение веб-атак:** Wazuh SIEM на логах веб-сервера; обнаружил, что стандартные правила пропускают логическую SQL-инъекцию, написал собственное правило обнаружения и проверил его в `wazuh-logtest`.
- **Монитор брутфорс-атак на SSH (Python):** парсер логов с пороговыми значениями, обогащением через GeoIP и оповещениями в Telegram; настройка через переменные окружения, модульные тесты и CI на GitHub Actions.
- **Отчёты по инцидентам и аудиту:** 5 разборов инцидентов (tcpdump, Wireshark) и оценка мер защиты по NIST CSF / PCI DSS / GDPR с планом устранения недостатков.

НАВЫКИ

Безопасность приложений: OWASP Top 10, аутентификация и авторизация (JWT), валидация входных данных, безопасность вебхуков (HMAC), работа с секретами, анализ бизнес-логики

Разработка: C#, ASP.NET Core, EF Core, Hangfire, Python, FastAPI, Django / DRF, TypeScript, React, PostgreSQL, REST

Инфраструктура и инструменты: Docker, Traefik / TLS, Linux, Bash, Git, GitHub Actions, Wazuh, Suricata, Nmap, Wireshark

Языки: русский — родной, английский — A2 (изучаю)

СЕРТИФИКАТЫ И ОБРАЗОВАНИЕ

- **Google Cybersecurity Professional Certificate** (Coursera) — в процессе, пройдено 3 из 8 курсов
- **Основы программирования на C** — Stepik, 2025
- **Башкирский экономико-юридический колледж** — банковское дело и финансовые услуги, 2017 — 2019